



Hashicorp Vault - інструмент управління секретами



Вступ

Що ж, якщо ви створюєте надійну програму, ймовірно, що ваші функції вимагають доступу до секретів або будь-якої іншої конфіденційної інформації, яку ви зберігаєте.

Ці секрети можуть включати:

- Ключі API
- Облікові дані бази даних
- Ключі шифрування
- Конфіденційні налаштування конфігурації (адреса електронної пошти, імена користувачів, позначки налагодження тощо)
- Паролі

Що таке HashiCorp Vault і як воно працює?

Оскільки багато організацій переходять на публічну хмару, головною проблемою є те, як найкраще захистити дані, запобігаючи несанкціонованому доступу або викраденню.

Розгортання такого продукту, як HashiCorp Vault, дає вам кращий контроль над конфіденційними обліковими даними та допомагає відповідати стандартам хмарної безпеки.

У цій публікації ми запропонуємо загальний огляд того, що таке HashiCorp Vault, і поділимося кількома варіантами використання, ілюструючи, наскільки це важливий інструмент DevOps для хмарної безпеки вашої організації.

Що таке HashiCorp Vault?

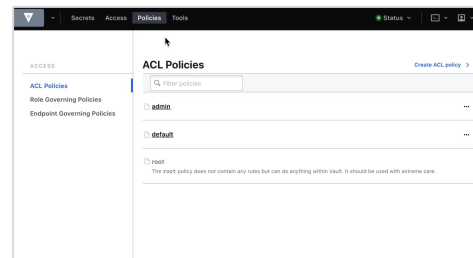
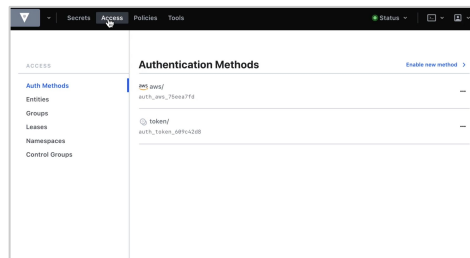
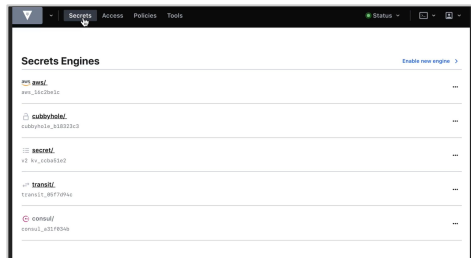
HashiCorp Vault розроблений, щоб допомогти організаціям керувати доступом до секретів і безпечно передавати їх усередині організації. Секрети визначаються як будь-яка форма конфіденційних облікових даних, які потребують суворого контролю та моніторингу та можуть використовуватися для розблокування конфіденційної інформації. Секрети можуть бути у формі паролів, ключів API, ключів SSH, токенів RSA або OTP.

HashiCorp Vault дозволяє дуже легко контролювати та керувати доступом, надаючи вам односторонній інтерфейс для керування кожним секретом у вашій інфраструктурі. Крім того, ви також можете створювати докладні журнали аудиту та відстежувати, хто до чого звертався.

Vault

HashiCorp Vault — це інструмент для безпечного зберігання та доступу до секретів. Він забезпечує уніфікований інтерфейс для таємниці, зберігаючи жорсткий контроль доступу та реєструючи повний журнал аудиту. Це інструмент, який захищає програми користувача та базу, щоб обмежити поверхневий простір і час атаки в разі порушення. Він надає API, який дозволяє отримати доступ до секретів на основі політик. Будь-який користувач API повинен перевірити та бачити лише ті секрети, на які він має право переглядати.

Vault шифрує дані за допомогою 256-бітного AES із GCM.



Як працює HashiCorp Vault?

HashiCorp Vault — це інструмент керування секретами, спеціально розроблений для контролю доступу до конфіденційних облікових даних у середовищі з низьким рівнем довіри. Його можна використовувати для зберігання конфіденційних значень і водночас динамічно генерувати доступ для конкретних послуг/додатків, які орендуються. Крім того, Vault можна використовувати для автентифікації користувачів (машин або людей), щоб переконатися, що вони мають доступ до певного файлу.

Автентифікація може здійснюватися за допомогою паролів або за допомогою динамічних значень для створення тимчасових маркерів, які дозволяють отримати доступ до певного шляху. Політики, написані за допомогою мови конфігурації HashiCorp (HCL), використовуються для визначення того, хто отримує який доступ.

Тепер, коли ми розглянули, що таке HashiCorp Vault, давайте розглянемо деякі речі, для яких воно використовується.

Vault

Він може накопичувати дані в різних серверах, таких як Amazon DynamoDB, Consul та багато іншого. Vault підтримує реєстрацію в локальний файл для служб аудиту, сервер Syslog або безпосередньо в сокет. Сховище реєструє інформацію про клієнта, який діяв, IP-адресу клієнта, дію та час її виконання

Запуск/перезапуск завжди включає одного або кількох операторів, щоб розпечатати Сховище. Він працює в основному з токенами. Кожен маркер надається політиці, яка може обмежувати дії та шляхи. Ключові особливості Vault:

- Він шифрує та розшифровує дані, не зберігаючи їх.
- Vault може генерувати секрети на вимогу для деяких операцій, наприклад баз даних AWS або SQL.
- Дозволяє реплікацію в кількох центрах обробки даних.
- Сховище має вбудований захист для секретного відкликання.
- Служить секретним сховищем з деталями контролю доступу.

Для чого використовується HashiCorp Vault?

HashiCorp Vault можна використовувати різними способами; ми виділили деякі з основних випадків використання нижче.

Управління секретами

HashiCorp Vault можна використовувати для зберігання будь-яких типів секретів, включаючи конфіденційні змінні середовища, облікові дані бази даних, ключі API тощо, надаючи користувачам контроль над тим, хто має доступ, а хто ні. Використання Vault дозволяє отримати повний контроль над будь-якими конфіденційними обліковими даними з можливістю ротації та відкликання доступу в будь-який час.

Завдяки HashiCorp Vault ви можете бути впевнені, що ваші облікові дані в безпеці порівняно зі збереженням відкритих текстових файлів у вашому управлінні конфігурацією (наприклад).

Замість того, щоб зберігати звичайні текстові файли для всього світу, ви можете налаштувати зчитування сховища запитів до програми або API HashiCorp, який захищає звичайні текстові версії цих файлів.

Секрети також легко обертати та відкликати; якщо співробітник залишає вашу організацію, ви можете легко та безпечно скасувати його доступ.

Для чого використовується HashiCorp Vault?

Доступ на основі ідентифікації

HashiCorp Vault використовує доступ на основі ідентифікаційної інформації для посередницького доступу до систем і секретів. Коли справа доходить до автентифікації за допомогою ідентичності, є два головних учасники: люди та машини.

Керування доступом для людей здійснюється за допомогою рольового контролю доступу (RBAC), надання дозволів і обмеження доступу для створення та керування секретами або керування доступом інших користувачів на основі секретного значення, з яким вони ввійшли в систему.

З іншого боку, керування доступом для машин передбачає надання доступу до різних серверів або секретів. Завдяки динамічній природі HashiCorp Vault ви можете створювати секрети, які тимчасово працюють, і скасовувати доступ у разі злому. Ви можете генерувати секрети на вимогу для певної системи, наприклад Sensitive, AWS або Consul, і генерувати пару ключів із дійсним дозволом. Після використання згенеровані динамічні секрети будуть автоматично відкликані.

Для чого використовується HashiCorp Vault?

Шифрування даних

Vault надає «шифрування як послугу», шифруючи дані під час передачі (за допомогою TLS) і в стані спокою (за допомогою 256-бітного шифрування AES CBC). Це захищає конфіденційні дані від несанкціонованого доступу двома основними способами: під час їх переміщення по вашій мережі, а також у сховищі у вашій хмарі та центрах обробки даних.

Завдяки централізованому управлінню ключами можна легко оновлювати та розгортати нові ключі в розподіленій інфраструктурі.

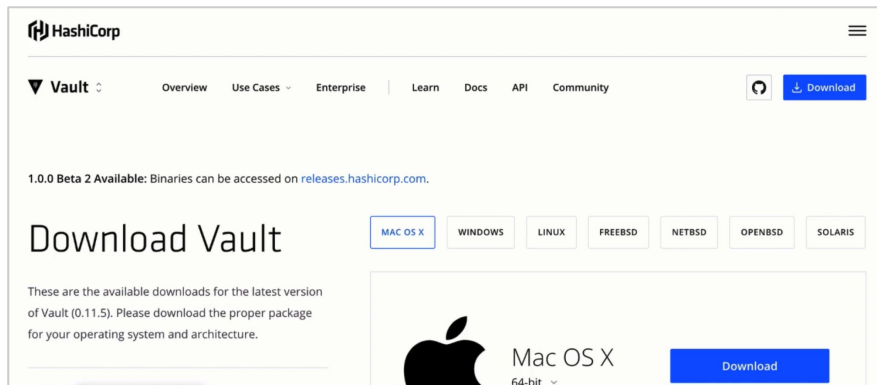


Встановлення

Встановити Vault

Спершу потрібно встановити Vault на вашому комп'ютері. Vault доступний у вигляді вихідного коду, попередньо скомпільованого двійкового файлу або в упакованих форматах. Щоб інсталювати Vault, знайдіть відповідний пакет для вашої системи та завантажте його. Vault запаковано як zip-архів. Після завантаження Vault розпакуйте пакет. Vault працює як єдиний двійковий файл під назвою vault. Будь-які інші файли в пакеті можна безпечно видалити, і Vault працюватиме.

Останнім кроком є переконання, що двійковий файл сховища доступний у PATH.



Перевірка встановлення

Після інсталяції Vault переконайтеся, що він працює, відкривши новий термінальний сеанс і перевіряючи, чи доступний двійковий файл сховища. Запустивши vault, ви повинні побачити вихід довідки, подібний до такого:

Якщо ви отримуєте повідомлення про те, що двійковий файл не знайдено, це означає, що ваша змінна середовища PATH не налаштована належним чином. Будь ласка, поверніться назад і переконайтеся, що ваша змінна PATH містить каталог, де встановлено Vault.

В іншому випадку Vault встановлено та готово до роботи!

```
$ vault
```

```
Usage: vault <command> [args]
```

Common commands:

read	Read data and retrieves secrets
write	Write data, configuration, and secrets
delete	Delete secrets and configuration
list	List data or secrets
login	Authenticate locally
server	Start a Vault server
status	Print seal and HA status
unwrap	Unwrap a wrapped secret

Other commands:

audit	Interact with audit devices
auth	Interact with auth methods
lease	Interact with leases
operator	Perform operator-specific tasks
path-help	Retrieve API help for paths
policy	Interact with policies
secrets	Interact with secrets engines
ssh	Initiate an SSH session
token	Interact with tokens

Питання та відповіді